CRISC Domains C and D – 100 Real-Life Questions

Risk Response, Controls, Monitoring, IT and Security – Practical Scenarios

CRISC Mastery Series

October 23, 2026

Instructions

How to Use This Deck

Think like a risk practitioner in a real organization.
Focus on business context, ownership, and practical decision-making.
The answer and a key takeaway are on the slide following each question.

Outline

1. Risk Response and Ownership
2. Third-Party Risk Management
3. Control Design, Implementation and Testing
4. Monitoring, Logging and Reporting
5. Architecture, Networks and Cloud
6. Resilience, Data and System Development
7. Emerging Technology, Security and Privacy
8. Conclusion

Q1: Choosing a Response

Question

A moderate risk is found on a low-value internal wiki. Fixing it would cost far more than the potential loss. What is the **MOST** appropriate response?

(A) Mitigate it anyway to be safe

(B) Buy a new cyber insurance policy just for the wiki

(C) Accept the risk, with documented approval from the risk owner

(D) Shut down every internal wiki in the company

Q1: Explanation

Correct Answer: C

- A response should be cost-effective compared with the exposure.
- Acceptance is valid when the risk is within appetite and formally documented.
- Spending more than the potential loss is poor risk management.

Key Takeaway

Never spend more on a control than the risk it addresses.

Q2: Who Accepts the Risk?

Question

The security team proposes accepting a high risk that affects the sales order process. Who should **formally** approve the acceptance?

(A) The Chief Information Security Officer

(B) The internal audit manager

(C) The business owner of the sales order process

(D) The IT service desk manager

Q2: Explanation

Correct Answer: C

- The risk owner is accountable for the business process and its outcomes.
- Security advises and recommends; it does not own the business risk.
- Audit is independent and must not accept risk on behalf of management.

Key Takeaway

Risk is accepted by the process owner, not by the team that found it.

Q3: Residual Risk Above Appetite

Question

After controls are applied, residual risk still exceeds the approved risk appetite. What should the risk practitioner do **NEXT**?

(A) Lower the risk appetite so the risk fits inside it

(B) Escalate to the risk owner and senior management for a decision on further response or a formal exception

(C) Close the risk because controls were implemented

(D) Re-rate the residual risk lower so it looks acceptable

Q3: Explanation

Correct Answer: B

- Appetite is set by leadership, not adjusted to fit one risk.
- Residual risk beyond appetite needs a management decision.
- Changing ratings to hide a gap defeats the purpose of risk management.

Key Takeaway

If residual risk is outside appetite, the decision goes up, not around.

Q4: Cyber Insurance

Question

A company buys cyber insurance to cover ransomware losses. Which statement about the remaining risk is **MOST** accurate?

(A) All ransomware risk has been eliminated

(B) Accountability, reputational damage, and operational disruption remain with the organization

(C) Accountability has moved to the insurer

(D) The likelihood of an attack has dropped significantly

Q4: Explanation

Correct Answer: B

- Insurance transfers part of the financial impact only.
- It does not stop attacks or reduce their likelihood.
- Customers, regulators, and the board still hold the organization accountable.

Key Takeaway

You can transfer some of the cost, never the accountability.

Q5: What Is Avoidance?

Question

A company wants to launch a product in a country whose data laws conflict with its own obligations and cannot be satisfied. Which action is risk **avoidance**?

(A) Buy insurance for regulatory fines

(B) Add stronger encryption and launch anyway

(C) Decide not to launch the product in that country

(D) Launch and monitor for complaints

Q5: Explanation

Correct Answer: C

- Avoidance removes the activity that creates the risk.
- Insurance is transfer, encryption is mitigation, and monitoring is acceptance.
- Avoidance is appropriate when no other response brings risk within appetite.

Key Takeaway

Avoidance means not doing the risky thing.

Q6: Selecting a Response

Question

Several response options exist for the same risk. Which factor is **MOST** important when choosing among them?

(A) Which option the vendor recommends

(B) Which option is the most technically advanced

(C) The cost-benefit of each option and how well it brings risk within appetite

(D) Which option can be deployed fastest

Q6: Explanation

Correct Answer: C

- The goal is to bring risk within appetite at an acceptable cost.
- Technology or speed alone does not justify a response.
- Vendors have a sales interest and are not neutral.

Key Takeaway

Best response = within appetite at reasonable cost.

Q7: Slipping Action Plans

Question

A mitigation plan was approved six months ago and its target dates keep slipping. What should the risk practitioner do?

(A) Report the delay to the risk owner and reassess whether the current exposure is still acceptable

(B) Remove the item from the risk register

(C) Extend the dates quietly without telling anyone

(D) Escalate to the board without talking to the owner

Q7: Explanation

Correct Answer: A

- The risk exists until it is actually reduced.
- The owner must know the exposure and decide whether to keep waiting.
- Silent extensions hide ongoing exposure.

Key Takeaway

A late action plan means the risk is still open.

Q8: Policy Exceptions

Question

A business unit asks for a temporary exception to the password policy for a legacy application. What is the **BEST** approach?

(A) Deny all exceptions without discussion

(B) Assess the risk, require compensating controls, set an expiry date, and obtain owner approval

(C) Grant it verbally to keep the business moving

(D) Rewrite the policy to match the legacy application

Q8: Explanation

Correct Answer: B

- Exceptions are normal but must be risk-assessed and time-bound.
- Compensating controls reduce exposure while the gap exists.
- Undocumented exceptions are unmanaged risk.

Key Takeaway

An exception without an expiry date is a permanent gap.

Q9: Legacy System Without MFA

Question

A critical legacy system cannot support multi-factor authentication. What should the risk practitioner recommend?

(A) Implement compensating controls such as segmentation, restricted access, and enhanced monitoring, and document the exception

(B) Accept the risk and take no action

(C) Replace the system immediately regardless of cost

(D) Remove the system from the asset inventory

Q9: Explanation

Correct Answer: A

- Compensating controls reduce risk when the preferred control is not possible.
- Immediate replacement may not be cost-justified or feasible.
- Hiding the asset makes the risk invisible, not smaller.

Key Takeaway

When the ideal control is impossible, compensate and document.

Q10: Secondary Risk

Question

Moving backups to a cloud provider reduces the risk of local data loss but creates new exposure of the backup data. What is this new exposure called?

(A) Inherent risk

(B) Residual risk of the original scenario

(C) Risk capacity

(D) Secondary risk, which must be assessed as part of the response

Q10: Explanation

Correct Answer: D

- A response can introduce new risks of its own.
- These must be evaluated before the response is approved.
- Ignoring them can leave the organization worse off.

Key Takeaway

Every response can create a new risk; check for it.

Q11: How Much Risk Remains?

Question

Management asks how much risk will remain once all planned controls are fully implemented. Which measure answers this?

(A) Inherent risk

(B) Residual risk

(C) Risk capacity

(D) Risk appetite

Q11: Explanation

Correct Answer: B

- Residual risk is what is left after controls are applied.
- Inherent risk is the level before any controls.
- Appetite and capacity describe how much risk the organization is willing or able to take.

Key Takeaway

Inherent minus controls equals residual.

Q12: Risk With No Owner

Question

A risk has been in the register for nine months with no assigned owner. What should the risk practitioner do **FIRST**?

(A) Work with senior management to assign an owner who is accountable for the affected business process

(B) Assign it to the risk practitioner to speed things up

(C) Assign it to the IT department by default

(D) Close the risk because nobody is concerned

Q12: Explanation

Correct Answer: A

- An owner must have authority and accountability for the process.
- Practitioners advise on risk; they should not own business risk.
- Unowned risks tend to go unmanaged.

Key Takeaway

A risk without an owner is a problem, not a managed risk.

Q13: Prioritizing Responses

Question

The budget is limited and many risks need action. How should responses be **prioritized**?

(A) Cheapest fix first

(B) Most technically interesting first

(C) By risk level against appetite and business impact, agreed with the risk owners

(D) Most recently discovered first

Q13: Explanation

Correct Answer: C

- Prioritization should follow exposure and business impact.
- Owners must agree because they bear the consequences.
- Cost, novelty, or recency alone can leave critical risks open.

Key Takeaway

Spend where the business exposure is highest.

Q14: Validating a New Control

Question

A mitigation project has just been completed. What should the risk practitioner do **NEXT**?

(A) Validate that the control works as intended and update the residual risk in the register

(B) Close the item without any validation

(C) Wait for the next annual assessment

(D) Inform only the audit team

Q14: Explanation

Correct Answer: A

- Implementation does not prove effectiveness.
- Residual risk must reflect the real control performance.
- Timely updates keep the register reliable for decisions.

Key Takeaway

Implemented is not the same as effective.

Q15: Onboarding a Vendor

Question

The business wants to onboard a vendor that will process customer data. What should the risk practitioner do **FIRST**?

(A) Sign the contract to avoid delaying the project

(B) Ask only for a penetration test report

(C) Give the vendor access to a test environment

(D) Perform due diligence and a risk assessment based on the data involved and the vendor's criticality

Q15: Explanation

Correct Answer: D

- Risk depends on the data, the service, and the vendor's controls.
- Contracts should reflect the findings of the assessment.
- Access is granted only after risk is understood.

Key Takeaway

Assess before you sign.

Q16: Contract Provisions

Question

Which contract provision **MOST** helps the organization oversee a vendor's control environment?

(A) A guaranteed price for three years

(B) Right to audit and a requirement to provide independent assurance reports

(C) An automatic renewal clause

(D) A marketing statement about industry leadership

Q16: Explanation

Correct Answer: B

- Oversight needs the ability to verify controls.
- Independent reports provide objective evidence.
- Commercial terms do not provide assurance about security.

Key Takeaway

Trust, but verify: contract for the right to check.

Q17: Fourth Parties

Question

A vendor hosts your data with a subcontractor. What is the **BEST** way to manage this exposure?

(A) Ignore it, since the subcontractor is not your vendor

(B) Ask the subcontractor to sign your employee handbook

(C) Cancel the contract automatically

(D) Require the vendor to disclose subcontractors and flow down your security and privacy requirements

Q17: Explanation

Correct Answer: D

- You remain accountable for your data wherever it is processed.
- Flow-down clauses make the vendor responsible for its suppliers.
- Visibility into the chain is needed to assess true risk.

Key Takeaway

Your data's risk includes your vendor's vendors.

Q18: Qualified SOC Report

Question

A vendor's SOC 2 report contains a qualified opinion on access management. What is the **BEST** action?

(A) Ignore it because the vendor has a SOC 2 report

(B) Terminate the contract immediately without analysis

(C) Accept the report as it is without review

(D) Assess the impact on your own risk, discuss remediation with the vendor, and consider compensating controls

Q18: Explanation

Correct Answer: D

- A qualification signals a control weakness that may affect you.
- The impact depends on your data and use of the service.
- The response should be proportionate and risk-based.

Key Takeaway

Read the report, not just the cover page.

Q19: Vendor Breach Notice

Question

A vendor reports a breach that may involve your customer data. What should be done **FIRST**?

(A) Wait for the vendor to finish its investigation

(B) Terminate the contract that day

(C) Activate incident response, gather facts from the vendor, and assess impact against contractual and regulatory obligations

(D) Notify all customers before any facts are known

Q19: Explanation

Correct Answer: C

- Your own incident process should start immediately.
- Decisions on notification depend on verified facts and obligations.
- Premature action can cause harm and legal exposure.

Key Takeaway

Facts first, then notification and contract decisions.

Q20: Ongoing Vendor Monitoring

Question

How should the organization decide how often to reassess a critical vendor?

(A) Only at contract signing

(B) Every ten years for all vendors

(C) Only after an incident occurs

(D) Based on criticality and risk, with periodic reviews plus reviews triggered by significant events

Q20: Explanation

Correct Answer: D

- Higher-risk vendors need more frequent oversight.
- Triggers include breaches, mergers, and service changes.
- One-time assessments become outdated quickly.

Key Takeaway

Vendor risk changes, so monitoring must continue.

Q21: Concentration Risk

Question

Ninety percent of critical services depend on one cloud provider. Which concern is **MOST** relevant?

(A) Only the monthly cost of the service

(B) There is no concern because the provider is large

(C) The concern applies only to small vendors

(D) Concentration risk, requiring an assessment of exit strategy and alternatives

Q21: Explanation

Correct Answer: D

- Heavy dependence on one provider increases impact if it fails.
- An exit or contingency plan reduces lock-in and outage risk.
- Size does not guarantee resilience.

Key Takeaway

Depend on one provider and you inherit its failures.

Q22: Vendor Offboarding

Question

A vendor contract is ending. Which risk activity is **MOST** important at termination?

(A) Delete the vendor from the accounting system only

(B) Keep access active in case of future work

(C) Confirm return or secure destruction of data and revoke all access, with evidence

(D) Send a thank-you letter

Q22: Explanation

Correct Answer: C

- Data and access can remain exposed after the relationship ends.
- Evidence of destruction supports compliance.
- Access removal prevents misuse of dormant accounts.

Key Takeaway

The risk does not end when the contract does.

Q23: Control Types

Question

A badge reader denies building entry to anyone without authorization. What type of control is this?

(A) Detective

(B) Corrective

(C) Preventive

(D) Directive

Q23: Explanation

Correct Answer: C

- Preventive controls stop an event before it occurs.
- Detective controls identify events after or while they happen.
- Corrective controls restore normal operation after an event.

Key Takeaway

Preventive stops it, detective finds it, corrective fixes it.

Q24: Reviewing Privileged Logs

Question

A manager reviews privileged access logs every day for unusual activity. This is **BEST** described as which type of control?

(A) Detective

(B) Preventive

(C) Corrective

(D) Compensating by definition

Q24: Explanation

Correct Answer: A

- The review finds activity that has already occurred.
- It does not block the action itself.
- Detective controls are most useful when responses are timely.

Key Takeaway

If it looks back to find problems, it is detective.

Q25: Defense in Depth

Question

Why does the organization use several layers of security controls instead of one very strong control?

(A) No single control is perfect, so layers reduce the chance that one failure leads to compromise

(B) Auditors require at least three controls per risk

(C) Layers always cost less than one strong control

(D) Layers remove the need for monitoring

Q25: Explanation

Correct Answer: A

- Controls can fail or be bypassed.
- Independent layers reduce the chance of total failure.
- Layers still need monitoring and maintenance.

Key Takeaway

Assume any single control can fail.

Q26: Shiny Tool Request

Question

Management wants to buy a popular security tool after reading a magazine review. What should the risk practitioner do **FIRST**?

(A) Approve the purchase to show support

(B) Compare only the vendor's feature lists

(C) Ask a competitor for a demonstration

(D) Confirm which identified risk the tool would reduce and whether the cost is justified

Q26: Explanation

Correct Answer: D

- Controls should be tied to identified risks.
- Cost-benefit analysis validates the investment.
- Features do not equal risk reduction.

Key Takeaway

Start with the risk, not the product.

Q27: Admin Access Request

Question

A developer asks for permanent administrator rights on the production environment. What is the **BEST** response?

(A) Grant full permanent rights to avoid delays

(B) Refuse and give no alternative

(C) Share an existing admin password

(D) Grant only the access needed, time-limited and approved, with activity logged

Q27: Explanation

Correct Answer: D

- Least privilege limits the impact of mistakes and misuse.
- Time-bound access reduces standing exposure.
- Shared credentials destroy accountability.

Key Takeaway

Give the minimum access, for the minimum time.

Q28: Segregation of Duties

Question

One employee can create vendor records and approve payments to them. What is the **BEST** recommendation?

(A) Trust the employee because of long service

(B) Remove all payment approvals

(C) Separate the duties, or add compensating controls such as independent review of changes

(D) Rely on the annual audit to detect problems

Q28: Explanation

Correct Answer: C

- Combining incompatible duties enables fraud and error.
- Separation or independent review reduces that risk.
- Annual audits detect issues late.

Key Takeaway

No single person should control a transaction end to end.

Q29: Design vs Operation

Question

A well-designed access review control is not being performed by the managers responsible. Which type of weakness is this?

(A) A design deficiency

(B) A weakness in inherent risk

(C) A scope limitation

(D) An operating effectiveness weakness

Q29: Explanation

Correct Answer: D

- The control exists on paper but is not carried out.
- A design deficiency means the control could not work even if performed.
- The fix is accountability and monitoring, not redesign.

Key Takeaway

A good design that is not performed is still a failure.

Q30: Strongest Test Evidence

Question

Which approach gives the **STRONGEST** evidence that a control operated effectively over the period?

(A) Re-performing the control on a sample of evidence from throughout the period

(B) Interviewing the control owner

(C) Reading the control description

(D) Obtaining management's written assertion

Q30: Explanation

Correct Answer: A

- Re-performance and inspection rely on actual evidence.
- Interviews and assertions are weaker, self-reported evidence.
- Samples should cover the whole review period.

Key Takeaway

Evidence beats explanations.

Q31: Post-Implementation Review

Question

What is the primary purpose of a post-implementation review of a new control?

(A) Assign blame for project delays

(B) Verify that the control achieves its intended risk reduction and meets requirements

(C) Prepare the vendor invoice for payment

(D) Update the organization chart

Q31: Explanation

Correct Answer: B

- The review confirms the control delivers the expected benefits.
- Findings feed lessons learned and residual risk updates.
- Its focus is value and effectiveness, not blame.

Key Takeaway

Check that the control delivered what was promised.

Q32: Ownerless Control

Question

A key control fails repeatedly and nobody takes responsibility. What is the **BEST** action?

(A) Replace the control with a policy statement

(B) Remove the control to avoid false assurance

(C) Have audit operate the control

(D) Assign a control owner with defined responsibilities and performance measures

Q32: Explanation

Correct Answer: D

- Controls need accountable owners.
- Defined measures show when the control is not working.
- Audit must stay independent of operating controls.

Key Takeaway

No owner, no control.

Q33: Manual Access Reviews

Question

Manual quarterly access reviews are repeatedly missed. Which improvement is **MOST** effective?

(A) Automate scheduling and tracking, for example with an identity governance tool, and monitor completion

(B) Send a stronger reminder email once a year

(C) Cancel the reviews

(D) Ask audit to complete them

Q33: Explanation

Correct Answer: A

- Automation improves consistency and evidence.
- Monitoring completion shows whether reviews are done.
- Cancelling or outsourcing to audit removes the control or independence.

Key Takeaway

Automate repeatable controls where practical.

Q34: Secure Baselines

Question

New servers are built inconsistently, creating random security gaps. Which control is **BEST**?

(A) Standard secure configuration baselines with automated compliance checking

(B) A longer written policy

(C) More frequent vulnerability meetings

(D) Let each administrator decide the settings

Q34: Explanation

Correct Answer: A

- Baselines give a repeatable secure starting state.
- Automated checks detect drift.
- Policy alone does not enforce consistent builds.

Key Takeaway

Standardize the build; do not rely on memory.

Q35: Reorganization and Controls

Question

After a reorganization, several controls no longer match how work is performed. What should the risk practitioner do?

(A) Leave the controls as they are

(B) Reassess control design against current processes and risks, and update where needed

(C) Remove all controls tied to the old structure

(D) Wait for audit to find the gaps

Q35: Explanation

Correct Answer: B

- Controls must fit the current process.
- Business change often creates gaps and overlaps.
- Proactive review avoids audit surprises.

Key Takeaway

Change the business, then recheck the controls.

Q36: Policy Not Followed

Question

Policy requires laptop encryption, but a review finds many unencrypted laptops. How should this be treated?

(A) As a documentation error only

(B) As an acceptable condition because the policy is old

(C) As a control gap that needs risk assessment and a response plan

(D) As a matter for HR only

Q36: Explanation

Correct Answer: C

- Non-compliance with policy creates exposure.
- Impact depends on the data stored and the likelihood of loss.
- The response should be owned and tracked.

Key Takeaway

A policy is only as good as its enforcement.

Q37: Why a SIEM?

Question

What is the primary value of a SIEM to the risk program?

(A) It aggregates and correlates logs from many sources to detect anomalies and support investigations

(B) It replaces the need for firewalls

(C) It prevents all attacks automatically

(D) It stores only employee emails

Q37: Explanation

Correct Answer: A

- Correlation reveals patterns that single logs miss.
- It supports incident response and compliance evidence.
- It is a detective and analysis tool, not a complete defense.

Key Takeaway

A SIEM finds the pattern, not the whole cure.

Q38: Protecting Logs

Question

Which measure **BEST** protects logs from tampering by an intruder?

(A) Store logs only on the server that generated them

(B) Allow all administrators to edit logs

(C) Delete logs weekly

(D) Forward logs to centralized, write-protected storage with restricted access

Q38: Explanation

Correct Answer: D

- Attackers often try to alter local logs to hide activity.
- Central, protected storage preserves evidence.
- Limiting access supports accountability.

Key Takeaway

Logs are evidence; protect them like evidence.

Q39: Alert Fatigue

Question

The monitoring team ignores most alerts because of high false positives. What is the **BEST** improvement?

(A) Turn off alerting for noisy systems

(B) Tune detection rules and prioritize alerts by risk

(C) Hire more staff only to read every alert

(D) Lower all alert thresholds

Q39: Explanation

Correct Answer: B

- Tuning improves signal quality.
- Risk-based prioritization focuses attention on what matters.
- Disabling or flooding alerts increases the chance of missing real events.

Key Takeaway

Reduce the noise before you add people.

Q40: Log Retention

Question

How should the retention period for logs be determined?

(A) By available disk space only

(B) By the administrator's preference

(C) By the shortest period that auditors have ever requested

(D) Based on legal, regulatory, investigative, and business requirements

Q40: Explanation

Correct Answer: D

- Different laws and contracts require different periods.
- Investigations may need older data.
- Retention should be defined in policy.

Key Takeaway

Retention is a policy decision, not a storage decision.

Q41: Setting KRI Thresholds

Question

How should KRI thresholds be **BEST** set?

(A) At whatever level produces few alerts

(B) By copying another company's values

(C) At the level the technology team prefers

(D) Aligned with the risk appetite and tolerance approved by management

Q41: Explanation

Correct Answer: D

- Thresholds define when risk becomes unacceptable.
- They should reflect decisions on appetite and tolerance.
- Arbitrary thresholds create false comfort or constant alarms.

Key Takeaway

A threshold is appetite translated into numbers.

Q42: Too Many KRIs

Question

A dashboard shows 80 KRIs and executives cannot tell which matter. What is the **BEST** action?

(A) Add more indicators for completeness

(B) Hide the dashboard from executives

(C) Reduce to a manageable set linked to key risks and the decisions they support

(D) Replace indicators with a single color

Q42: Explanation

Correct Answer: C

- Indicators should drive decisions.
- A focused set is easier to monitor and act on.
- Removing visibility or detail does not help management.

Key Takeaway

Measure what you will act on.

Q43: A Leading Indicator

Question

Which metric is the **BEST** leading indicator for phishing risk?

(A) The number of past breaches last year

(B) A rising click rate in simulated phishing campaigns

(C) Total annual loss from fraud

(D) Average time to close helpdesk tickets

Q43: Explanation

Correct Answer: B

- Leading indicators signal increasing exposure before incidents occur.
- Past breaches and losses are lagging measures.
- Ticket time is unrelated to phishing susceptibility.

Key Takeaway

Leading indicators warn; lagging indicators report.

Q44: Control Self-Assessment

Question

What is a key benefit of control self-assessment (CSA)?

(A) It replaces independent audit completely

(B) It involves process owners in evaluating their own controls and builds ownership

(C) It guarantees an unqualified opinion

(D) It eliminates the need for testing

Q44: Explanation

Correct Answer: B

- CSA increases awareness and accountability in the first line.
- Results should still be validated independently.
- It supplements rather than replaces audit.

Key Takeaway

CSA builds ownership; it does not replace independence.

Q45: Continuous Monitoring

Question

Why is continuous monitoring preferred over only periodic assessments for critical risks?

(A) It is always cheaper than assessments

(B) It detects changes in risk and control performance sooner, supporting timely response

(C) It removes the need for risk owners

(D) It is required for all risks regardless of importance

Q45: Explanation

Correct Answer: B

- Risk can change between assessment cycles.
- Timely information supports faster decisions.
- Intensity should match criticality.

Key Takeaway

Fast-moving risks need fast-moving information.

Q46: Tailoring Reports

Question

A risk practitioner sends the same detailed technical report to engineers and the board. What is the **BEST** improvement?

(A) Send the board more technical detail

(B) Send engineers only a one-line summary

(C) Stop reporting to the board

(D) Tailor the content and level of detail to each audience's decisions and needs

Q46: Explanation

Correct Answer: D

- Boards need risk versus appetite and decisions required.
- Engineers need actionable technical detail.
- One report cannot serve everyone.

Key Takeaway

Know your audience, then write.

Q47: Conflicting Metrics

Question

Risk metrics from two teams for the same control disagree. What should the practitioner do **FIRST**?

(A) Report the more favorable figure

(B) Average the two numbers

(C) Validate data sources and standardize definitions before reporting

(D) Remove the metric from the report

Q47: Explanation

Correct Answer: C

- Reports depend on reliable data.
- Common definitions make results comparable.
- Choosing the convenient number damages credibility.

Key Takeaway

Bad data makes a good report dangerous.

Q48: Triggers for Updates

Question

The company announces an acquisition. What should the risk practitioner do regarding the risk register?

(A) Wait until the next annual review

(B) Do nothing because acquisitions are not IT events

(C) Delete low risks to simplify the register

(D) Review and update risks and ownership to reflect the new environment

Q48: Explanation

Correct Answer: D

- Business changes can create new risks and change existing ones.
- Early updates keep the register decision-ready.
- Risk management is continuous, not annual.

Key Takeaway

Major business change means a risk refresh.

Q49: Overdue Audit Findings

Question

Remediation of a high-priority audit finding is overdue. What is the **BEST** action?

(A) Remove the finding from the report

(B) Extend the due date without review

(C) Accept the risk on behalf of the owner

(D) Escalate per governance procedures and confirm with the owner whether the exposure is still acceptable

Q49: Explanation

Correct Answer: D

- Overdue items reflect continuing exposure.
- Escalation ensures management is aware.
- Only the owner can accept risk.

Key Takeaway

Overdue findings are risks that someone must decide on.

Q50: Measuring Monitoring

Question

Which metric **BEST** indicates how effective an organization's monitoring capability is?

(A) Number of monitoring tools purchased

(B) Mean time to detect and respond to security incidents

(C) Number of log sources in the data center

(D) Total size of the log archive

Q50: Explanation

Correct Answer: B

- Detection and response times show real effectiveness.
- Tools, log volume, and storage measure activity, not results.
- Lower times indicate that issues are found and handled sooner.

Key Takeaway

Measure outcomes, not inventory.

Q51: Enterprise Architecture

Question

How does an enterprise architecture view help the risk practitioner?

(A) It replaces the risk register

(B) It shows systems, data flows, and dependencies so risk concentrations can be identified

(C) It guarantees compliance

(D) It is only useful for network engineers

Q51: Explanation

Correct Answer: B

- Architecture documents how components connect and depend on each other.
- Dependencies reveal single points of failure.
- It supports impact analysis for changes.

Key Takeaway

You cannot manage risk in a system you cannot map.

Q52: Capability Maturity

Question

A maturity assessment rates a key process at the lowest level, often called initial. What does this mean?

(A) The process is fully optimized

(B) The process is quantitatively managed

(C) The process has been independently certified

(D) The process is ad hoc, unpredictable, and dependent on individuals

Q52: Explanation

Correct Answer: D

- Low maturity means results are inconsistent.
- Higher levels bring documentation, measurement, and improvement.
- Maturity helps prioritize process investment.

Key Takeaway

Low maturity means heroics, not repeatability.

Q53: Flat Network

Question

Point-of-sale terminals share the same network as general office computers. What is the **BEST** recommendation?

(A) Install more antivirus on office computers only

(B) Segment the network so a compromise in one zone cannot easily spread to others

(C) Rename the network

(D) Increase the Wi-Fi password length

Q53: Explanation

Correct Answer: B

- Segmentation limits lateral movement.
- Sensitive systems should sit in controlled zones.
- Endpoint tools alone do not contain network-wide compromise.

Key Takeaway

Separate what is critical from what is convenient.

Q54: Firewall Rule Sprawl

Question

A firewall contains hundreds of old rules that no one can explain. What is the **BEST** action?

(A) Leave the rules, because deleting is risky

(B) Add a rule allowing all traffic temporarily

(C) Perform a regular rule review and remove unneeded rules through change management

(D) Disable logging to reduce clutter

Q54: Explanation

Correct Answer: C

- Unused rules widen the attack surface.
- Changes must be controlled and tested.
- Logging is needed to understand what is used.

Key Takeaway

Review the rule base like you review user access.

Q55: IDS vs IPS

Question

Which statement correctly distinguishes an IDS from an IPS?

(A) An IDS detects and alerts, while an IPS can also block suspicious traffic

(B) An IDS blocks traffic, while an IPS only logs

(C) They are identical devices

(D) An IPS is used only for wireless networks

Q55: Explanation

Correct Answer: A

- Detection systems generate alerts for analysis.
- Prevention systems are placed inline and can act automatically.
- Both need tuning to limit false positives.

Key Takeaway

IDS watches; IPS watches and acts.

Q56: Fake Website

Question

Users type the correct web address but land on a fraudulent site. Which attack is **MOST** likely?

(A) Brute-force password guessing

(B) DNS poisoning or spoofing

(C) Denial of service

(D) SQL injection against the user's laptop

Q56: Explanation

Correct Answer: B

- Corrupted DNS answers redirect users to attacker sites.
- Controls include secure resolvers and DNS security extensions.
- Monitoring unusual DNS records helps detection.

Key Takeaway

If the address is right but the site is wrong, suspect DNS.

Q57: Guest Wi-Fi

Question

Guests connect to a Wi-Fi network that also reaches internal servers. What is the **BEST** fix?

(A) Place guest access on a separate, isolated network with strong encryption and authentication

(B) Hide the network name

(C) Ask guests to be careful

(D) Move the servers to a new building

Q57: Explanation

Correct Answer: A

- Isolation prevents guests from reaching internal systems.
- Encryption protects traffic.
- Hiding a network name is not a security control.

Key Takeaway

Guests get internet, not the internal network.

Q58: Remote Access

Question

Employees work from public networks. Which control **BEST** protects their connection to company systems?

(A) A shared password sent by email

(B) Disabling endpoint updates

(C) A VPN with multi-factor authentication

(D) Allowing direct internet access to servers

Q58: Explanation

Correct Answer: C

- A VPN encrypts traffic over untrusted networks.
- MFA reduces the impact of stolen credentials.
- Direct exposure increases attack surface.

Key Takeaway

Treat every public network as hostile.

Q59: Shared Responsibility: IaaS

Question

In an infrastructure-as-a-service model, who is responsible for patching the guest operating system?

(A) The cloud provider

(B) The customer

(C) The internet service provider

(D) The hardware manufacturer

Q59: Explanation

Correct Answer: B

- The provider secures the underlying infrastructure.
- The customer manages what it deploys on top, including operating systems.
- Responsibilities should be confirmed in the contract.

Key Takeaway

The more control you have, the more you must secure.

Q60: Shared Responsibility: SaaS

Question

Even when using a SaaS application, what does the customer **ALWAYS** remain responsible for?

(A) Data classification, user access management, and configuration choices

(B) Physical data center security

(C) Hypervisor patching

(D) Provider network hardware

Q60: Explanation

Correct Answer: A

- SaaS shifts infrastructure duties to the provider.
- The customer still decides who can access which data.
- Accountability for the data remains with the customer.

Key Takeaway

You can outsource the service, not the data accountability.

Q61: Cloud Exposure Root Cause

Question

What is the **MOST** common root cause of data exposures in cloud environments?

(A) Physical theft of provider hardware

(B) Rare failures in encryption mathematics

(C) Lack of electricity

(D) Misconfiguration of storage, identity, or network settings

Q61: Explanation

Correct Answer: D

- Default or careless settings can make data public.
- Continuous configuration monitoring catches drift.
- Least privilege limits damage when mistakes happen.

Key Takeaway

Most cloud breaches start with a setting, not a genius.

Q62: Multi-Tenancy

Question

Which risk is **MOST** specific to multi-tenant public cloud environments?

(A) Employees working from home

(B) Printer supply shortages

(C) Failure of logical separation between customers' data and workloads

(D) Lack of paper records

Q62: Explanation

Correct Answer: C

- Tenants share underlying infrastructure.
- Isolation depends on the provider's design and configuration.
- Encryption and assurance reports help manage this risk.

Key Takeaway

Shared infrastructure demands strong isolation.

Q63: Cloud Logging

Question

The organization wants visibility into activity in a cloud service. What is the **BEST** approach?

(A) Assume the provider will alert the customer

(B) Disable logs to reduce cost

(C) Review logs once at year end

(D) Enable cloud activity logs and integrate them into central monitoring, agreeing access in the contract

Q63: Explanation

Correct Answer: D

- The customer is responsible for monitoring its own use.
- Central integration enables correlation with other sources.
- Retention and access should be contractually defined.

Key Takeaway

If you cannot see it, you cannot monitor it.

Q64: Zero Trust

Question

Which statement **BEST** describes the zero trust principle?

(A) Trust everyone inside the office network

(B) Trust devices that were approved last year

(C) Trust any user with a company email address

(D) Never trust implicitly based on network location; always verify identity and context

Q64: Explanation

Correct Answer: D

- Location alone is not proof of trustworthiness.
- Access decisions use identity, device health, and context.
- It limits the damage when one account is compromised.

Key Takeaway

Verify every request, every time.

Q65: Start With a BIA

Question

Before writing a business continuity plan, what should the organization do **FIRST**?

(A) Buy a secondary data center

(B) Write recovery scripts for all systems

(C) Perform a business impact analysis to identify critical processes and recovery needs

(D) Hire a continuity consultant before understanding processes

Q65: Explanation

Correct Answer: C

- The BIA identifies what matters most and how long it can be down.
- Recovery strategies depend on the results.
- Otherwise investment may not match business need.

Key Takeaway

Know what is critical before you plan to protect it.

Q66: Recovery Point Objective

Question

Management says the organization can tolerate losing at most 15 minutes of transactions. Which objective does this define?

(A) Recovery time objective (RTO)

(B) Recovery point objective (RPO)

(C) Maximum tolerable outage

(D) Service level agreement

Q66: Explanation

Correct Answer: B

- RPO describes acceptable data loss measured in time.
- It drives backup and replication frequency.
- RTO describes how quickly service must be restored.

Key Takeaway

RPO is about data, RTO is about time to recover.

Q67: Recovery Time Objective

Question

The order system must be back in service within four hours of an outage. Which objective does this describe?

(A) Recovery time objective (RTO)

(B) Recovery point objective (RPO)

(C) Risk appetite

(D) Key risk indicator

Q67: Explanation

Correct Answer: A

- RTO defines how quickly a service must be restored.
- It drives recovery strategy and cost.
- RPO covers the amount of data loss allowed.

Key Takeaway

RTO is the clock, RPO is the checkpoint.

Q68: Tabletop Only

Question

The disaster recovery plan has been tested only by tabletop discussion for three years. What is the **MOST** significant concern?

(A) The plan may not work technically, because actual recovery has never been demonstrated

(B) Tabletop tests are prohibited

(C) The plan is too short

(D) The team talks too much

Q68: Explanation

Correct Answer: A

- Discussion tests logic, not technical recovery.
- Functional tests prove that systems can actually be restored.
- Test results should drive plan updates.

Key Takeaway

A plan never exercised is a hope, not a capability.

Q69: Untested Backups

Question

Backups run nightly, but restores have never been tried. What should the risk practitioner recommend?

(A) Increase backup frequency only

(B) Perform periodic restore tests and record the results

(C) Trust the backup software reports

(D) Encrypt the backup logs

Q69: Explanation

Correct Answer: B

- A backup is only valuable if it can be restored.
- Tests reveal corruption, missing data, or procedure gaps.
- Success reports do not prove recoverability.

Key Takeaway

A backup you cannot restore is not a backup.

Q70: Alternate Site Choice

Question

The RTO for a critical service is a few minutes. Which alternate site strategy is **MOST** appropriate?

(A) A hot site or active-active arrangement

(B) A cold site

(C) Manual workarounds only

(D) A storage unit with spare hardware

Q70: Explanation

Correct Answer: A

- Short RTOs require systems already running or ready to take over.
- Cold sites take much longer to become operational.
- Cost must be weighed against business impact.

Key Takeaway

The tighter the RTO, the hotter the site.

Q71: Classify First

Question

What should the organization do **FIRST** to apply appropriate protection to its data?

(A) Classify the data according to sensitivity and business value

(B) Encrypt every file with the same key

(C) Move everything to the cloud

(D) Delete all old records

Q71: Explanation

Correct Answer: A

- Classification drives which controls are appropriate.
- Uniform treatment wastes money or leaves critical data under-protected.
- Owners should confirm classifications.

Key Takeaway

You cannot protect data properly until you know what it is.

Q72: Data Hoarding

Question

Customer records from over ten years ago are kept indefinitely with no business need. What is the **BEST** action?

(A) Keep everything because storage is cheap

(B) Move the data to personal drives

(C) Define a retention schedule and securely dispose of data that is no longer required

(D) Rename the files

Q72: Explanation

Correct Answer: C

- Unneeded data increases breach impact and compliance exposure.
- Retention should follow legal and business needs.
- Disposal must be secure and documented.

Key Takeaway

Data you do not have cannot be stolen.

Q73: Who Classifies Data?

Question

Who is **PRIMARILY** responsible for deciding how a business dataset is classified?

(A) The data custodian or system administrator

(B) The vendor hosting the data

(C) The data owner

(D) The help desk

Q73: Explanation

Correct Answer: C

- Owners understand business value and legal obligations.
- Custodians implement protection according to the classification.
- Responsibility should be recorded.

Key Takeaway

Owners decide, custodians implement.

Q74: Security Early in Development

Question

At which point in the development life cycle is it generally **MOST** cost-effective to address security?

(A) After go-live

(B) During requirements and design

(C) During annual audit

(D) After the first incident

Q74: Explanation

Correct Answer: B

- Early fixes are cheaper than rework later.
- Requirements should include security and privacy needs.
- Late discovery can delay or stop deployment.

Key Takeaway

Shift left: design it in, do not bolt it on.

Q75: Fast Releases

Question

An agile team releases weekly and skips security review to keep pace. What is the **BEST** solution?

(A) Stop all releases

(B) Review security only after each year

(C) Integrate automated security testing and checks into the delivery pipeline

(D) Let developers self-certify without testing

Q75: Explanation

Correct Answer: C

- Automation scales with speed.
- Early feedback helps developers fix issues quickly.
- Skipping checks accumulates hidden risk.

Key Takeaway

Make security part of the pipeline, not a roadblock.

Q76: Test Environment Data

Question

A project copies live customer data into a test environment with weaker controls. What is the **BEST** recommendation?

(A) Allow it because it is only a test

(B) Use masked or synthetic data for testing

(C) Give testers production admin rights

(D) Disable test logging

Q76: Explanation

Correct Answer: B

- Test systems often have weaker controls.
- Masking preserves usefulness while reducing exposure.
- Privacy obligations apply to copies of data.

Key Takeaway

Real data in test means real risk in test.

Q77: Squeezed Project Testing

Question

A project is behind schedule, and management proposes cutting security testing. What should the risk practitioner do?

(A) Approve quietly to support the schedule

(B) Explain the risk impact to the sponsor and let the accountable owner decide, with the decision documented

(C) Refuse and leave the project

(D) Complete the testing secretly

Q77: Explanation

Correct Answer: B

- Schedule pressure creates risk trade-offs.
- The business owner should decide knowingly.
- Documentation preserves accountability.

Key Takeaway

Make the trade-off visible, then let the owner decide.

Q78: System Accreditation

Question

What does formal accreditation of a system typically represent?

(A) Management's formal acceptance of the residual risk of operating the system

(B) Proof that the system has no vulnerabilities

(C) A guarantee from the vendor

(D) A budget approval for new hardware

Q78: Explanation

Correct Answer: A

- Certification evaluates controls; accreditation is the management decision.
- Acceptance should be based on documented risk information.
- Accountability stays with management.

Key Takeaway

Accreditation is a risk decision, not a guarantee.

Q79: Open-Source Components

Question

Developers rely heavily on open-source libraries. Which control **BEST** manages the associated risk?

(A) Track components in an inventory and scan them for known vulnerabilities and license issues

(B) Ban all open-source software with no analysis

(C) Download libraries from any source

(D) Assume popular libraries are always safe

Q79: Explanation

Correct Answer: A

- Third-party code can contain known vulnerabilities.
- An inventory enables fast response when issues appear.
- License terms can create legal obligations.

Key Takeaway

Know what is inside your software.

Q80: End-of-Life Systems

Question

A production system runs an operating system the vendor no longer supports. What is the **BEST** initial response?

(A) Ignore it, because the system still works

(B) Turn off all monitoring

(C) Assess the risk, plan an upgrade, and apply compensating controls until then

(D) Remove the system from inventory

Q80: Explanation

Correct Answer: C

- Unsupported software no longer receives security patches.
- Compensating controls limit exposure during transition.
- A documented plan and owner reduce uncertainty.

Key Takeaway

No patches means rising risk over time.

Q81: Bring Your Own Device

Question

Employees want to use personal phones for work email. Which approach **BEST** manages the risk?

(A) Ban phones entirely without alternatives

(B) Allow any device with no controls

(C) A BYOD policy with mobile device management, data separation, and user acknowledgment

(D) Ask employees to be careful

Q81: Explanation

Correct Answer: C

- Policy sets expectations and responsibilities.
- Management tools allow remote wipe and separation of work data.
- Blanket bans often lead to shadow practices.

Key Takeaway

Enable the business, but control the data.

Q82: Default Credentials on IoT

Question

Hundreds of IoT sensors were installed with default passwords. What is the **BEST** action?

(A) Leave them because they are small devices

(B) Connect them directly to the finance network

(C) Change defaults, keep an inventory, and place devices on a segmented network

(D) Disable all logging

Q82: Explanation

Correct Answer: C

- Default credentials are widely known.
- Segmentation limits what a compromised device can reach.
- An inventory is needed to manage updates.

Key Takeaway

Small devices can still be the way in.

Q83: AI Decision Model

Question

The business plans to use an AI model for credit decisions. Which concern should the risk practitioner emphasize **FIRST**?

(A) Bias, explainability, data quality, and human oversight within an AI governance process

(B) The color scheme of the user interface

(C) The number of servers the model runs on

(D) The vendor's brand reputation only

Q83: Explanation

Correct Answer: A

- Automated decisions can affect individuals unfairly.
- Poor data leads to poor and biased outcomes.
- Governance and accountability must be defined before use.

Key Takeaway

AI decisions still need a human owner.

Q84: Generative AI Data Leakage

Question

Staff are pasting confidential documents into a public generative AI tool. What is the **BEST** response?

(A) Ignore it because the tool is popular

(B) Publish a policy and take no further action

(C) Block the whole internet

(D) Set an acceptable use policy, offer an approved tool, and apply technical controls such as data loss prevention

Q84: Explanation

Correct Answer: D

- Policy gives direction; tools give enforcement.
- An approved alternative reduces shadow use.
- Overblocking harms productivity.

Key Takeaway

Give people a safe way to do what they will do anyway.

Q85: Blockchain Risk

Question

Which risk is **MOST** relevant when an organization records business data on a blockchain?

(A) Records are difficult to correct once written, and key management or smart contract flaws can cause loss

(B) Blockchains cannot store any data

(C) Blockchains are always faster than databases

(D) Blockchains require no governance

Q85: Explanation

Correct Answer: A

- Immutability makes mistakes and privacy requests hard to fix.
- Lost or stolen keys can cause irreversible loss.
- Smart contract code needs review and testing.

Key Takeaway

Immutable cuts both ways.

Q86: Quantum Computing

Question

Sensitive data must stay confidential for 25 years. What should the risk practitioner recommend regarding quantum computing?

(A) Ignore it until quantum computers are common

(B) Remove encryption altogether

(C) Use shorter passwords

(D) Inventory cryptography in use and plan migration to quantum-resistant algorithms

Q86: Explanation

Correct Answer: D

- Adversaries may store data now and decrypt it later.
- Knowing where cryptography is used makes migration possible.
- Long-lived data needs earlier planning.

Key Takeaway

Long-lived secrets need future-proof protection.

Q87: Leaver Accounts

Question

A terminated employee's account was still active two months later. What is the **BEST** long-term fix?

(A) Remind managers by email once a year

(B) Disable all accounts monthly

(C) Integrate HR termination events with automated account deprovisioning and review exceptions

(D) Rely on the employee to log out

Q87: Explanation

Correct Answer: C

- HR events are the most reliable trigger.
- Automation shortens the exposure window.
- Periodic reviews catch what automation misses.

Key Takeaway

Access should end when employment ends.

Q88: What Is MFA?

Question

Which of the following is an example of multi-factor authentication?

(A) Two different passwords

(B) A password and a security question

(C) A password combined with a one-time code from an authenticator app

(D) A long password

Q88: Explanation

Correct Answer: C

- MFA uses factors from different categories: know, have, or are.
- Passwords and security questions are both something you know.
- Different factors make a single compromise less damaging.

Key Takeaway

Two of the same kind is not multi-factor.

Q89: Shared Admin Account

Question

System administrators share one generic admin account. What is the **BEST** improvement?

(A) Change the shared password every year

(B) Individual accountable accounts with privileged access management and session logging

(C) Write the password on a secure note

(D) Increase the password length only

Q89: Explanation

Correct Answer: B

- Shared accounts remove accountability.
- Individual accounts and logs show who did what.
- Privileged access tools can enforce approval and recording.

Key Takeaway

If everyone is admin, no one is accountable.

Q90: Bulk Encryption

Question

Which type of encryption is **MOST** suitable for encrypting large volumes of data efficiently?

(A) Asymmetric encryption

(B) Symmetric encryption

(C) A hash function

(D) A digital signature

Q90: Explanation

Correct Answer: B

- Symmetric algorithms are fast for bulk data.
- Asymmetric methods are often used to exchange or protect the symmetric keys.
- Hashes are one-way and cannot be decrypted.

Key Takeaway

Symmetric for speed, asymmetric for key exchange.

Q91: Checking File Integrity

Question

How can a recipient confirm that a downloaded file was not altered?

(A) Check the file size only

(B) Open it and look for errors

(C) Rename it and scan again

(D) Compare its cryptographic hash value with the value published by the source

Q91: Explanation

Correct Answer: D

- Even a tiny change produces a different hash.
- The reference hash must come from a trusted channel.
- Size and appearance are unreliable checks.

Key Takeaway

A matching hash means unchanged.

Q92: What a Signature Provides

Question

Which combination does a digital signature provide?

(A) Confidentiality only

(B) Availability and performance

(C) Anonymity of the sender

(D) Authentication of the sender, integrity of the message, and non-repudiation

Q92: Explanation

Correct Answer: D

- The signature is created with the sender's private key.
- Any change to the message invalidates it.
- It does not by itself encrypt the content.

Key Takeaway

A signature proves who sent it and that it did not change.

Q93: Certificate Expiry Outage

Question

A critical website went down because a certificate expired unnoticed. What is the **BEST** preventive measure?

(A) Maintain a certificate inventory with expiry monitoring and renewal ownership

(B) Buy certificates that never expire

(C) Ignore certificates for internal systems

(D) Wait for users to report problems

Q93: Explanation

Correct Answer: A

- Expiry is predictable and preventable.
- Ownership ensures renewals are done.
- Monitoring warns before service is affected.

Key Takeaway

Certificates expire on schedule; plan for it.

Q94: Key Storage

Question

Encryption keys are stored on the same server as the data they protect. What is the **BEST** recommendation?

(A) Store keys separately in a hardened key management system or hardware security module

(B) Leave them because encryption is in place

(C) Email the keys to the administrators

(D) Store keys in a shared spreadsheet

Q94: Explanation

Correct Answer: A

- If an attacker gets both, encryption gives no protection.
- Separate, protected storage limits exposure.
- Key access must be restricted and logged.

Key Takeaway

Do not lock the door and tape the key to it.

Q95: Effective Awareness Training

Question

Which approach to security awareness training is **MOST** effective?

(A) One annual video for everyone

(B) Regular, role-based training with measured outcomes such as phishing simulations

(C) Training only for the IT department

(D) Training only after a breach

Q95: Explanation

Correct Answer: B

- Different roles face different risks.
- Repetition reinforces behavior.
- Metrics show whether behavior is improving.

Key Takeaway

Train often, tailor it, and measure it.

Q96: Data Minimization

Question

Marketing wants to collect many personal data fields from customers just in case they are useful later. What should the risk practitioner recommend?

(A) Collect everything while it is possible

(B) Collect more only from new customers

(C) Collect only the data necessary for a defined, lawful purpose

(D) Let marketing decide without review

Q96: Explanation

Correct Answer: C

- Less data means less exposure and less compliance burden.
- Purpose should be defined before collection.
- Excess data increases breach impact.

Key Takeaway

Collect what you need, not what you can.

Q97: Privacy Impact Assessment

Question

A new application will process personal data. What should be done **BEFORE** go-live?

(A) Wait for the first customer complaint

(B) Perform a privacy impact assessment and address the findings

(C) Delay all privacy work until after launch

(D) Assume the security review covers privacy

Q97: Explanation

Correct Answer: B

- A PIA identifies privacy risks early.
- Findings may change design or data handling.
- Security and privacy overlap but are not the same.

Key Takeaway

Assess privacy before launch, not after complaints.

Q98: Deletion Request

Question

A customer asks the company to delete all of their personal data. What is the **BEST** approach?

(A) Verify identity, check legal retention duties, and respond within the required timeframe

(B) Delete without any verification

(C) Ignore the request

(D) Ask the customer to call next year

Q98: Explanation

Correct Answer: A

- Requests must come from the verified data subject.
- Some data may need to be retained by law.
- Regulations define response deadlines.

Key Takeaway

Honor privacy rights through a defined, verified process.

Q99: Security vs Privacy

Question

Which statement **BEST** distinguishes data security from data privacy?

(A) Security protects data from unauthorized access, while privacy governs appropriate collection, use, and sharing of personal data

(B) They are the same thing

(C) Privacy applies only to encrypted data

(D) Security applies only to paper records

Q99: Explanation

Correct Answer: A

- A system can be secure yet misuse personal data.
- Privacy requires lawful and fair processing.
- Both are needed, and they work together.

Key Takeaway

Secure is not the same as private.

Q100: Cross-Border Data Transfer

Question

The company plans to move customer personal data to a data center in another country. What should be done **FIRST**?

(A) Move the data first and ask legal later

(B) Choose the cheapest country

(C) Assume all countries have identical rules

(D) Assess applicable laws and legal transfer mechanisms before moving the data

Q100: Explanation

Correct Answer: D

- Data transfer rules vary by jurisdiction.
- Non-compliance can lead to fines and forced stoppage.
- Contracts and safeguards may be required.

Key Takeaway

Know the law of the place your data lives.

Exam Mindset Summary

Remember These Core Principles

- **Owners Decide:** The risk owner accepts, mitigates, transfers, or avoids risk; practitioners advise.
- **Fit the Response:** Choose responses that bring risk within appetite at reasonable cost.
- **Controls Serve Risks:** Select, implement, and test controls based on identified risks.
- **Verify, Do Not Assume:** Evidence of effectiveness matters more than assertions or tool purchases.
- **Monitor Continuously:** Use well-chosen indicators tied to appetite to trigger timely action.
- **Understand Before Acting:** Know the architecture, data, and business context before choosing technical fixes.
- **Accountability Cannot be Outsourced:** Vendors and cloud providers share duties, but accountability remains with the organization.

Good Luck on Your CRISC Exam!

Real exam questions test your ability to apply these concepts in practical, real-world scenarios.